



GDPR

General Data Protection Regulation

Enforced Since 25 May 2018 · EU

[STUDY NOTES]

*"A regulation to protect personal data & privacy
of individuals within the European Union
and the European Economic Area."*

WHAT'S INSIDE

What is GDPR

7 Principles

Lawful Basis

Data Rights

Key Roles

Breach Rules

Privacy Design

Penalties



Yadav Ghorasainee

[linkedin.com/in/yadav-ghorasainee](https://www.linkedin.com/in/yadav-ghorasainee)

yadavgybernet.github.io/sec/

What is GDPR?

GDPR Overview

- Full Form: General Data Protection Regulation
- Enforced since 25 May 2018 across all EU/EEA states
- Issued by: The European Union (EU)
- Applies to ANY organisation handling EU residents' data

Key Objectives:

- Give individuals full control over their personal data
- Simplify the regulatory environment for businesses
- Ensure data is processed lawfully & transparently

Key Features:

- Rights-based approach to data protection
- Strict accountability & compliance framework

EXAMPLE:

A US-based online store sells products to EU customers.
Even though the business is NOT in Europe, it MUST comply with GDPR — because it processes EU residents' personal data.

7 Key Principles of GDPR

Article 5 — Core Principles

- **Lawfulness, Fairness & Transparency**

→ Process data legally, fairly, and in a clear open manner

- **Purpose Limitation**

→ Collected only for specific, explicitly stated purposes

- **Data Minimisation**

→ Collect only what is strictly necessary — nothing more

- **Accuracy**

→ Keep data accurate, complete and up to date at all times

- **Storage Limitation**

→ Do not retain data any longer than genuinely needed

- **Integrity & Confidentiality**

→ Secure data against breaches, loss and unauthorised access

- **Accountability**

EXAMPLE:

A hospital collects only patient name, DOB and diagnosis (Minimisation).

Records are encrypted at rest and in transit (Integrity & Confidentiality).

Retained only for the legally required period, then securely deleted.

Lawful Basis for Processing

Article 6 — 6 Legal Bases

- **1. Consent**

→ Individual gives clear, informed, unambiguous agreement

- **2. Contract**

→ Processing needed to fulfil a contract with the person

- **3. Legal Obligation**

→ Required by law (e.g. tax records, employment law)

- **4. Vital Interests**

→ Protect someone's life in an emergency

- **5. Public Task**

→ Carried out in the public interest or official authority

- **6. Legitimate Interests**

→ Genuine business need — must not override individual rights

EXAMPLE:

Newsletter sign-up with an UNTICKED checkbox = Valid Consent.

Employer processing payroll data = Legal Obligation basis.

Fraud detection by a bank = Legitimate Interests basis.

Data Subject Rights

8 Rights Guaranteed by GDPR

- **Right to be Informed**

→ Know how, why and by whom personal data is used

- **Right of Access (SAR)**

→ Request a free copy of all personal data held

- **Right to Rectification**

→ Correct inaccurate or incomplete data promptly

- **Right to Erasure — 'Right to be Forgotten'**

→ Request permanent deletion when no longer needed

- **Right to Restrict Processing**

→ Pause processing while a dispute is being resolved

- **Right to Data Portability**

→ Transfer personal data between service providers

- **Right to Object**

EXAMPLE:

User emails company requesting all their data to be deleted.

Company MUST confirm deletion and respond within 30 days.

Failure to comply can result in a complaint to the ICO.

Key Roles Under GDPR

Data Controller

- Decides the purpose and means of processing data
- Primarily and legally responsible for GDPR compliance
- Must establish a lawful basis before processing begins

Data Processor

- Processes personal data on behalf of the controller
- Must follow the controller's documented instructions only
- Must have a signed Data Processing Agreement (DPA)

Data Protection Officer (DPO)

- Mandatory for public bodies and large-scale processors
- Monitors internal GDPR compliance independently
- Acts as the main contact for supervisory authorities

EXAMPLE:

NHS Hospital (Controller) hires a Cloud IT firm (Processor) to host records. Both sign a Data Processing Agreement (DPA). The Hospital's DPO reviews the arrangement and monitors compliance on an ongoing basis.

Data Breach Notification

Articles 33 & 34 — Breach Obligations

What Counts as a Data Breach?

- Accidental or unlawful access to personal data
- Destruction, loss, alteration or unauthorised disclosure
- Ransomware attack that locks access to personal data

Notification Requirements:

- **Notify Supervisory Authority (e.g. ICO) within 72 hours**
- **Notify affected individuals without undue delay**
- Low risk breach → notify authority only, not individuals

Breach Record Must Document:

- Nature of breach and categories of data affected
- Number of individuals involved and records exposed

EXAMPLE:

Hospital database is hacked overnight — patient records exposed.

DPO must notify the ICO within 72 hours AND alert affected patients, explaining what happened and exactly what protective steps are taken.

Privacy by Design & Default

Article 25 — Built-in Privacy

Privacy by Design:

- Embed privacy protections into systems from day one
- Privacy is NOT an afterthought — built into architecture
- Proactive approach — prevent privacy issues before they occur

Privacy by Default:

- Most privacy-friendly settings must be ON by default
- Minimum necessary data is collected automatically
- Users must actively OPT-IN for any additional data sharing

7 Foundational Principles:

- Proactive not Reactive · Privacy as the Default Setting
- End-to-End Security · Full Functionality (no trade-offs)

EXAMPLE:

A new mobile banking app collects ONLY email at signup by default.
Location tracking is OFF by default — user must explicitly opt-in.
All data is encrypted in transit and at rest from the very first launch.

International Data Transfers

Chapter 5 — Cross-Border Transfers

3 Main Lawful Transfer Mechanisms:

- **Adequacy Decision**

- EU Commission confirms country offers adequate protection

- Approved countries: UK, Japan, Canada, South Korea, New Zealand

- **Standard Contractual Clauses (SCCs)**

- Pre-approved legal contracts ensuring GDPR-level rights

- Most common tool used for EU → US transfers today

- **Binding Corporate Rules (BCRs)**

- Internal rules for data transfers within the same corporate group

- Approved by the relevant Data Protection Authority (DPA)

Derogations (Exceptional Cases Only):

- Explicit consent · Vital interests · Legal claims

EXAMPLE:

EU fintech company transfers customer data to a US analytics firm.

They MUST sign Standard Contractual Clauses (SCCs) ensuring the US firm provides the same GDPR-level protections to all EU individuals.

Penalties & Enforcement

Article 83 — Administrative Fines

Tier 1 — Lower Level Violations:

- Up to EUR 10 Million
 - OR 2% of global annual turnover — whichever is HIGHER
- Covers: DPO obligations, processor failures, breach notification

Tier 2 — Higher Level Violations:

- Up to EUR 20 Million
 - OR 4% of global annual turnover — whichever is HIGHER
- Covers: Core principles, data subject rights, unlawful processing

Key Supervisory Authorities:

- ICO (UK) · CNIL (France) · BfDI (Germany)
- DPC (Ireland) · UODO (Poland) · AEPD (Spain)

EXAMPLE:

Meta (Facebook) fined EUR 1.2 Billion by the Irish DPC in May 2023 for unlawfully transferring EU user data to US servers without adequate GDPR protections — the largest GDPR fine in history.

Key Takeaways

GDPR Core Flow:



Key Principles:

- Rights-based thinking — people's privacy first, always
- Accountability & transparency embedded at the core
- Privacy by Design — not a bolt-on feature or afterthought
- Continuous compliance culture — review, improve, repeat

Remember:

- GDPR is not a one-time project — it is an ongoing obligation
- Every team member plays a role in protecting personal data

Thanks for Reading!

Save for reference · Share with your network · Apply GDPR in real work!

[linkedin.com/in/yadav-ghorasainee](https://www.linkedin.com/in/yadav-ghorasainee) | yadavgybernet.github.io/sec/